
TD SYNNEX
Microsoft
Microsoft
InnovAIte
INNOVATION POWERS ACTION

TD SYNNEX | Microsoft

Microsoft InnovAIte

Resilient Cloud with Azure: Security Strategies and Best Practices

CLASS PREREQUSITE:
- Microsoft Authenticator App

Anil Patel

Solution Architect, CLOUD ENABLEMENT SERVICES | TD SYNNEX

Zero Trust Principles

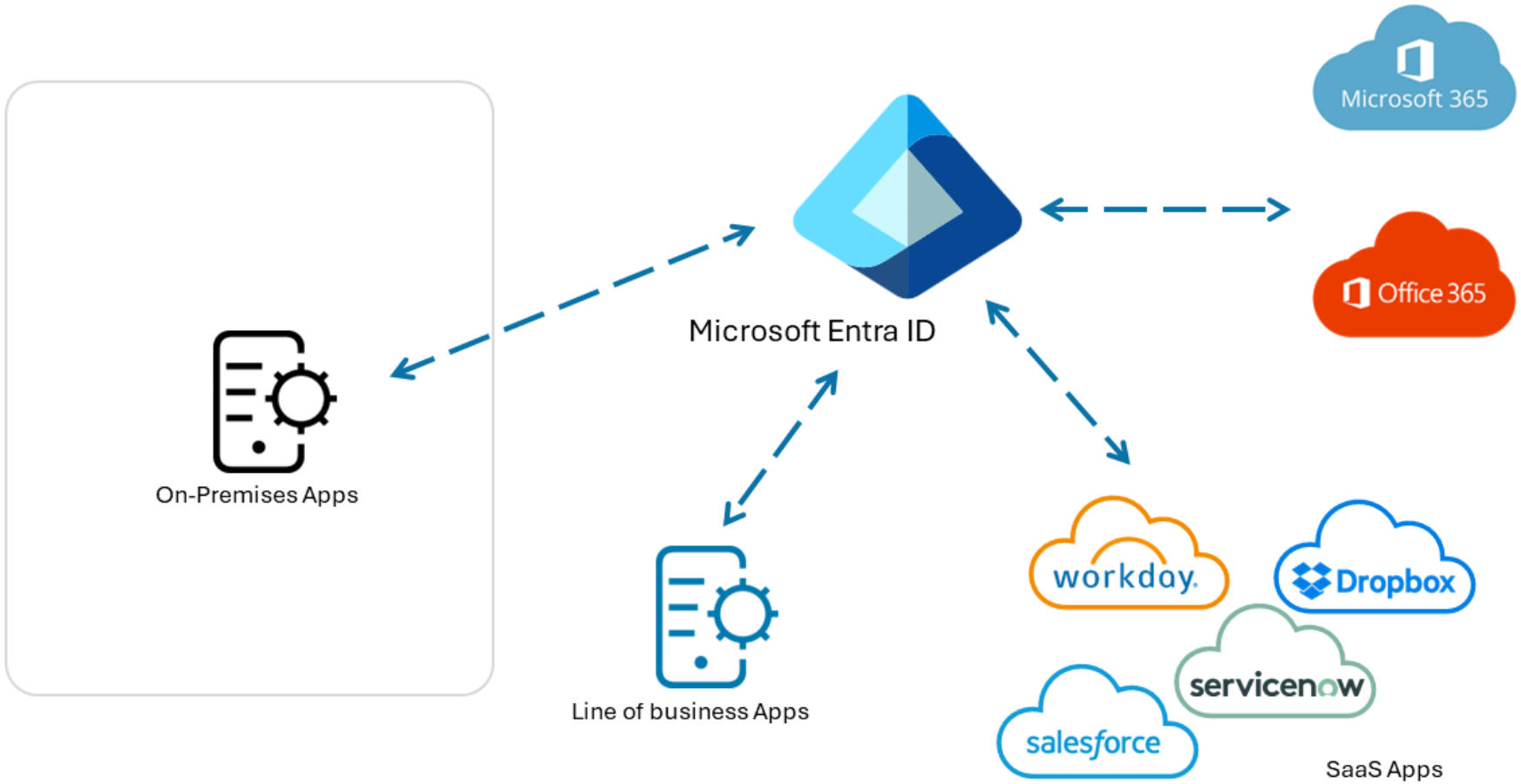


Verify explicitly

Use least privileged access

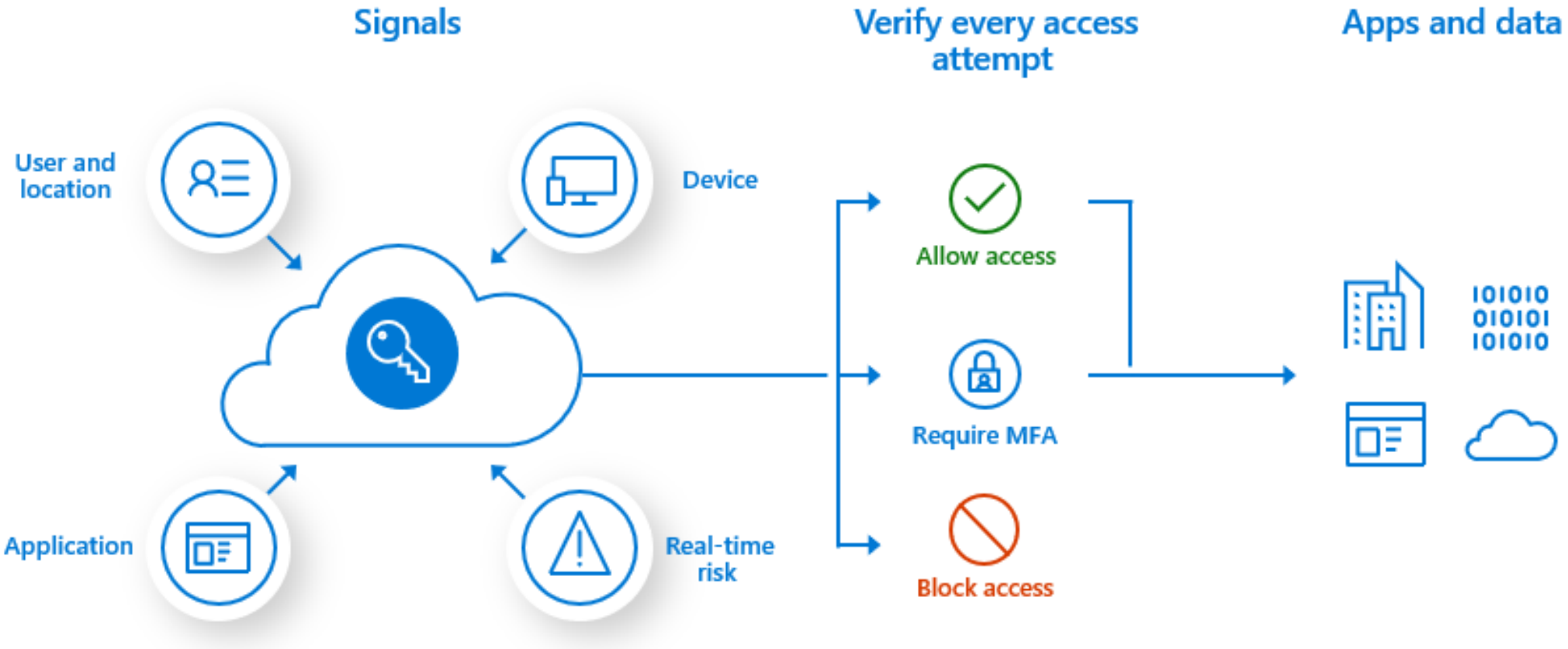
Assume breach

Entra ID

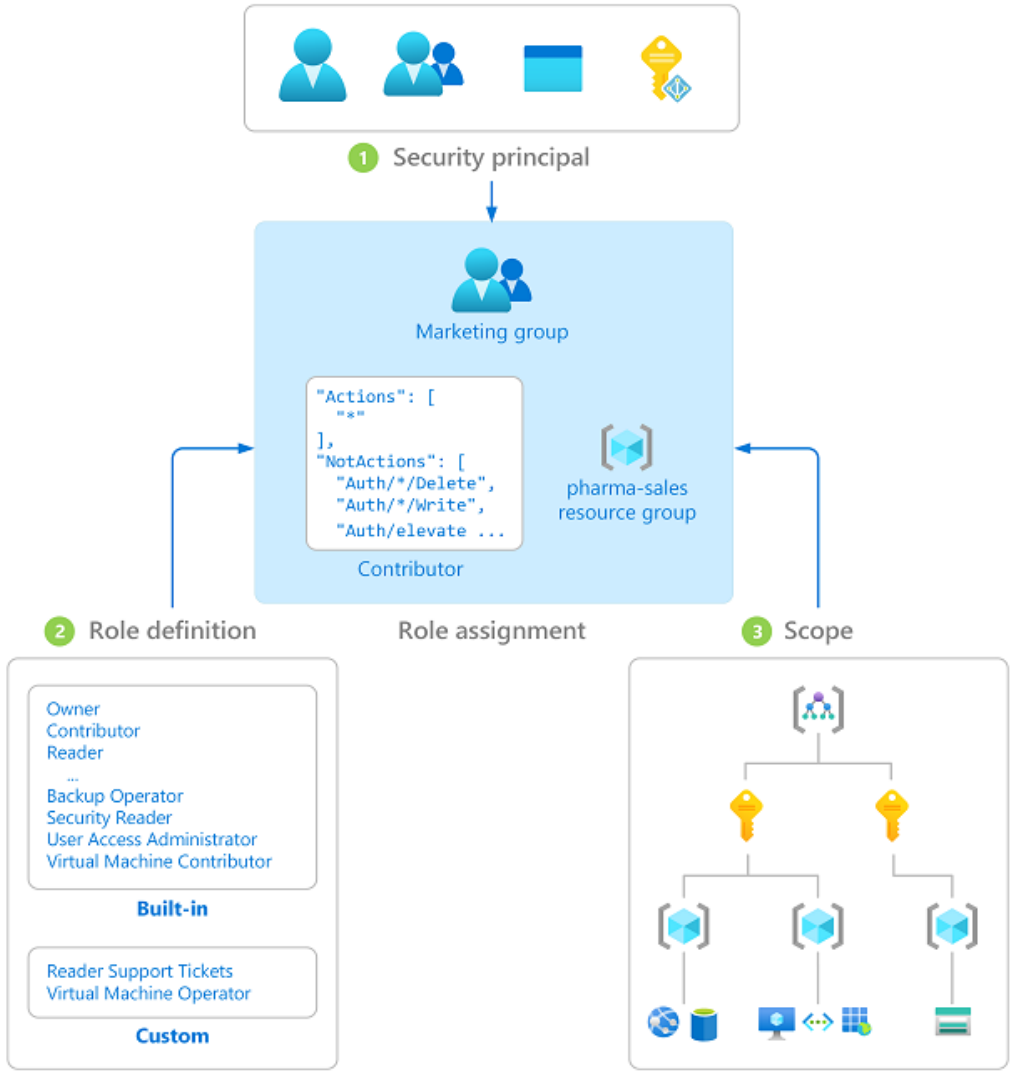

Microsoft 365
Office 365
Microsoft Entra ID
On-Premises Apps
Line of business Apps
workday.
Dropbox
servicenow
salesforce
SaaS Apps

Bad: Password	**Good:** Password and...	**Better:** Password and...	**Best:** Passwordless
123456	SMS	Authenticator (Push Notifications)	Authenticator (Phone Sign-in)
qwerty	Voice	Software Tokens OTP	Window Hello
password		Hardware Tokens OTP (Preview)	FIDO2 security key
iloveyou			Certificates
Password1			

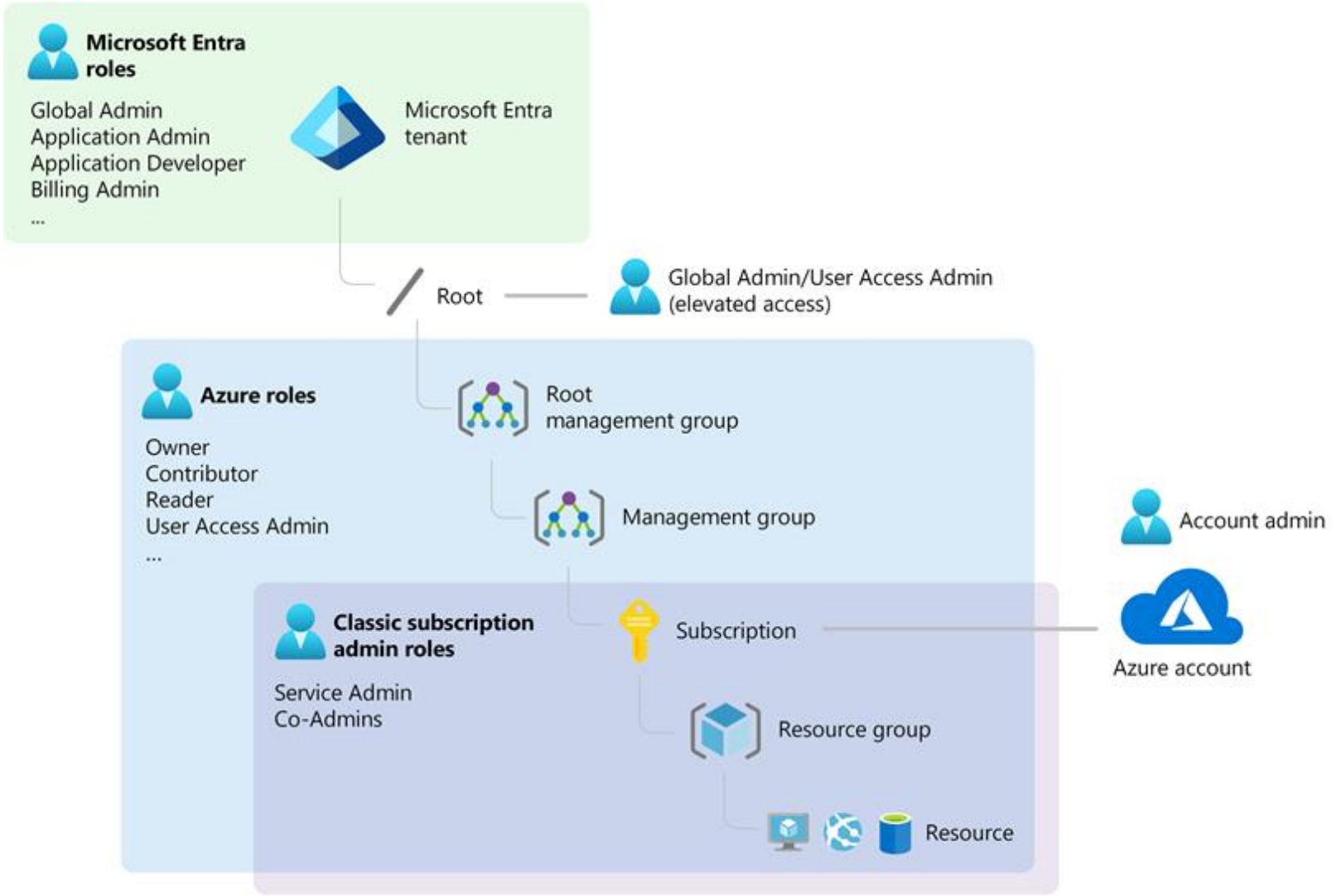
Conditional Access



Role Based Access Control



Role Based Access Control



Privileged Identity Management | Just-In-Time

- Reduce the chance of a malicious actor getting access and an authorized user inadvertently impacting a sensitive resource.
- Provide just-in-time privileged access to Microsoft Entra ID and Azure resources
- Assign time-bound access to resources using start and end dates
- Require approval to activate privileged roles
- Enforce multifactor authentication to activate any role
- Get notifications when privileged roles are activated
- Conduct access reviews to ensure users still need roles

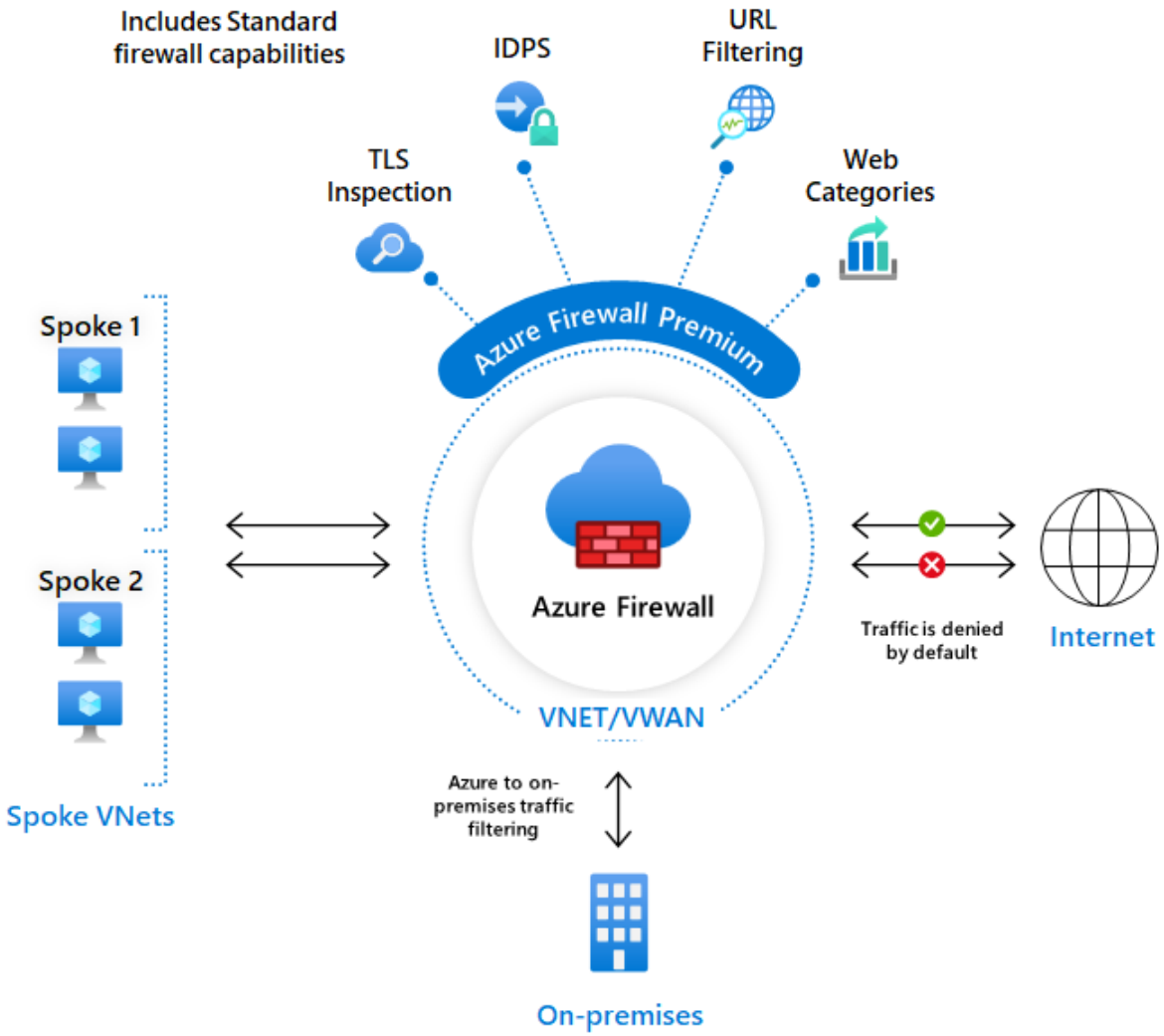
VNets

Azure Virtual Network provides the fundamental building block for your private network in Azure.

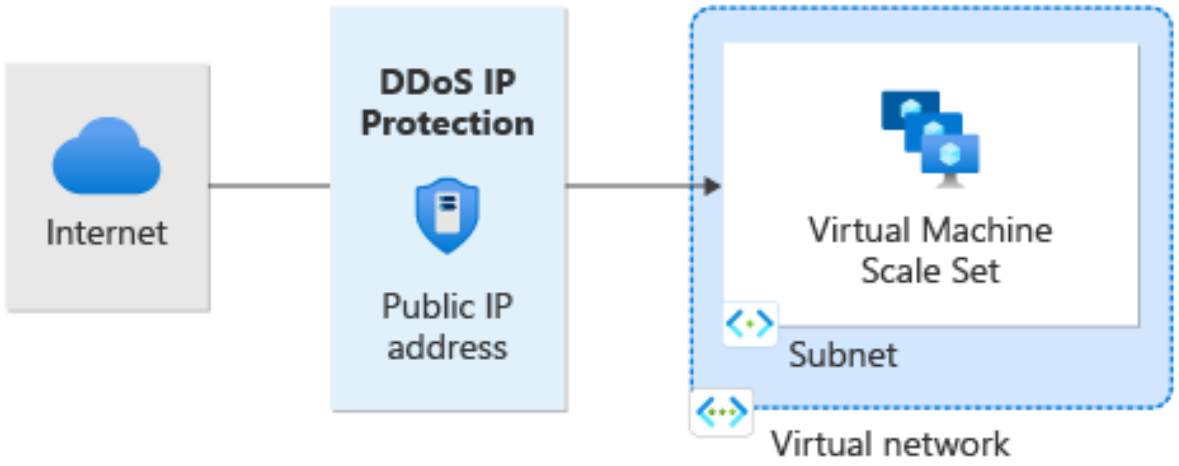
Use an Azure network security group to filter network traffic between Azure resources in an Azure virtual network.

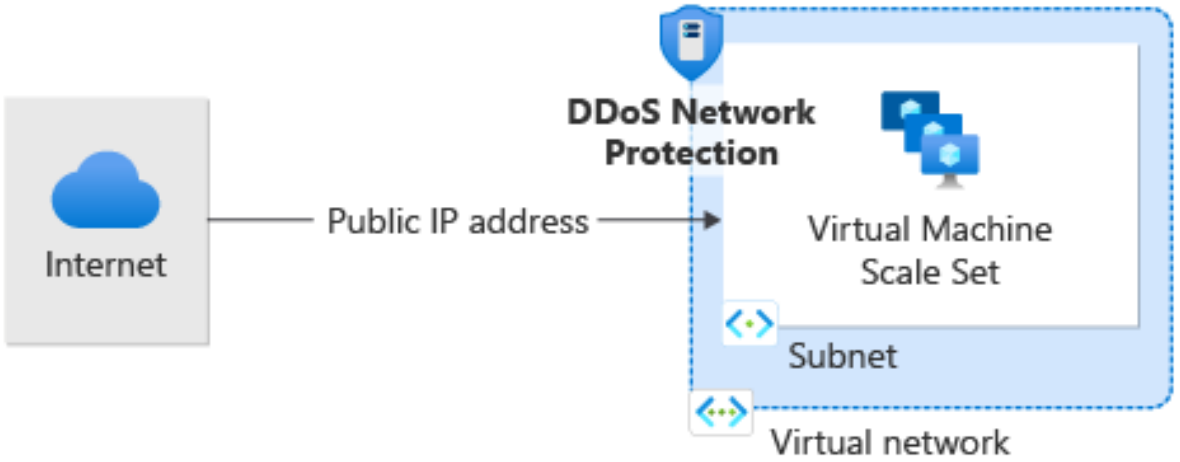
Application security groups enable you to configure network security as a natural extension of an application's structure, allowing you to group virtual machines and define network security policies based on those groups.

Azure Firewall : Premium, Standard, Basic

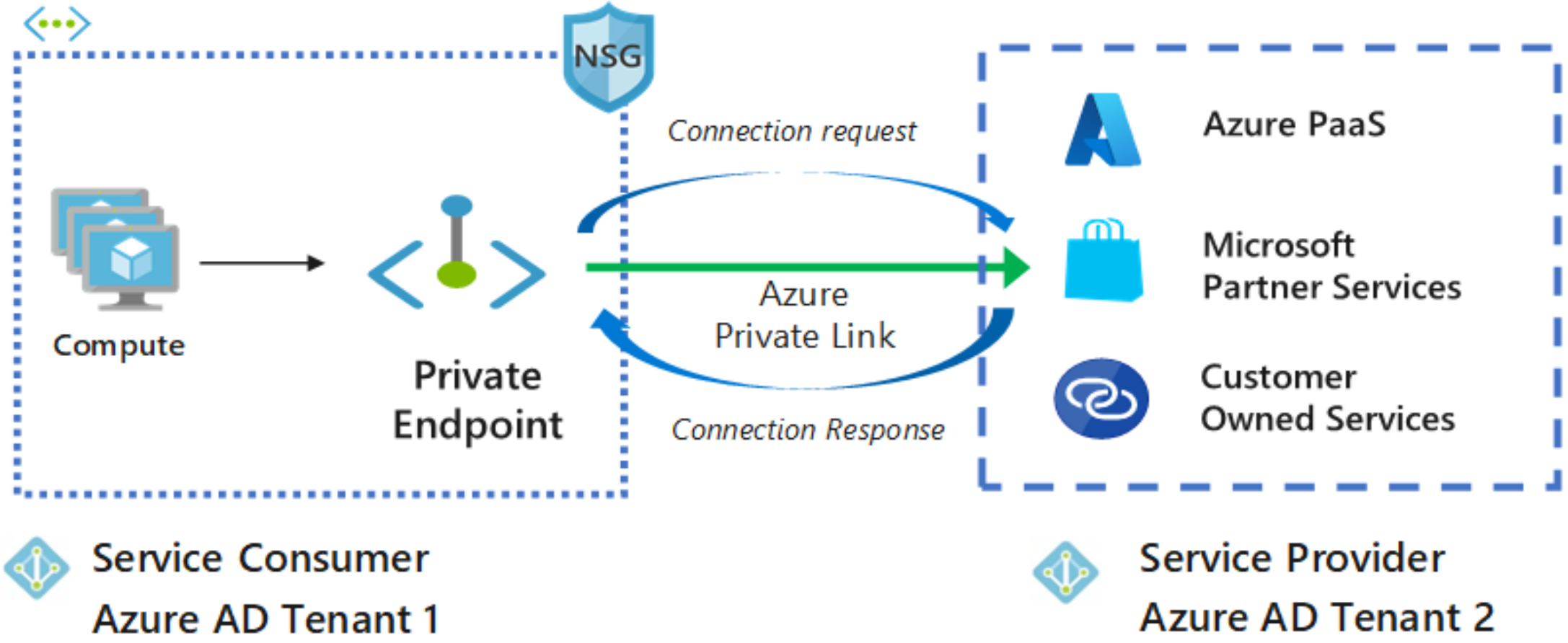


DDoS Protection

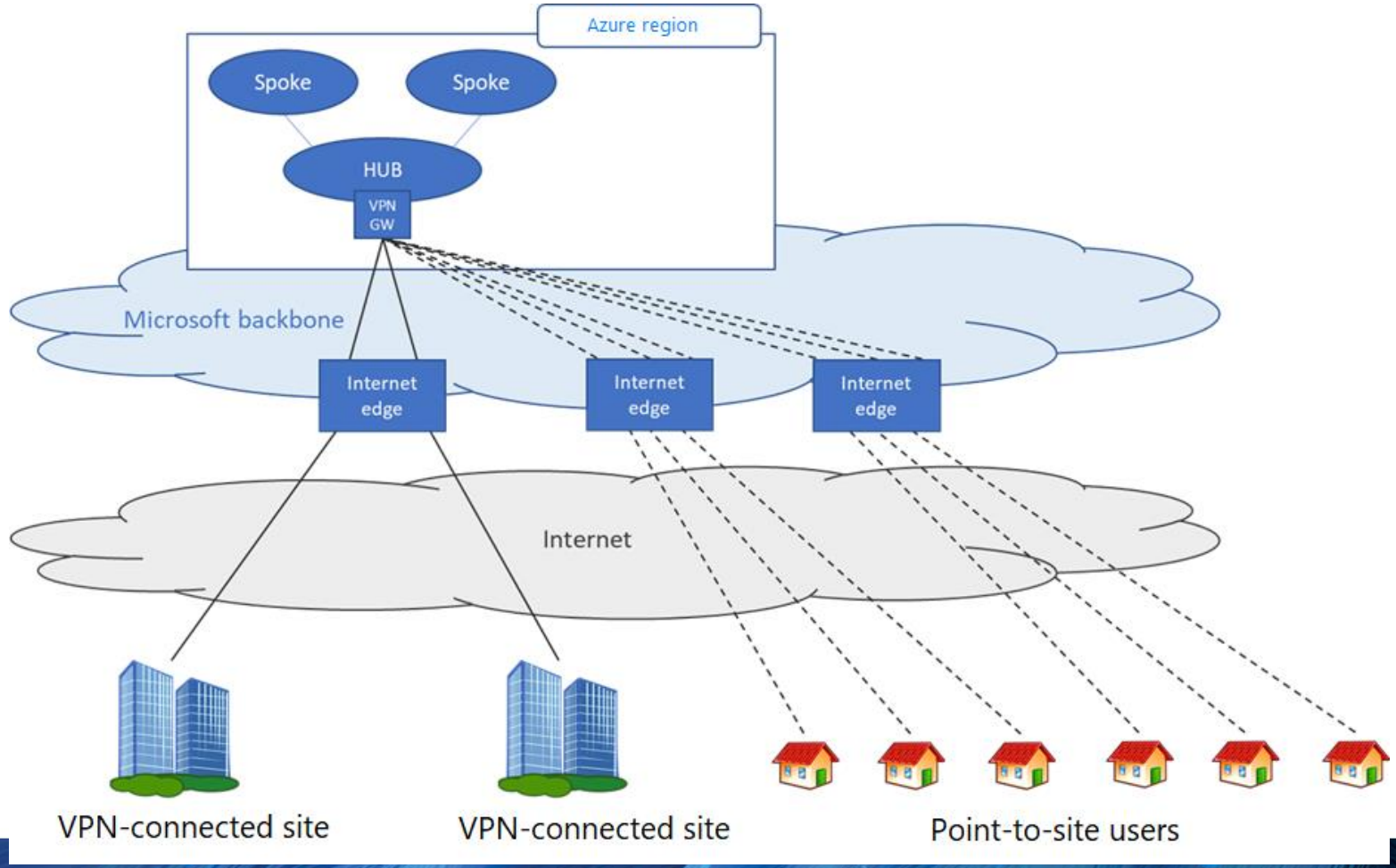




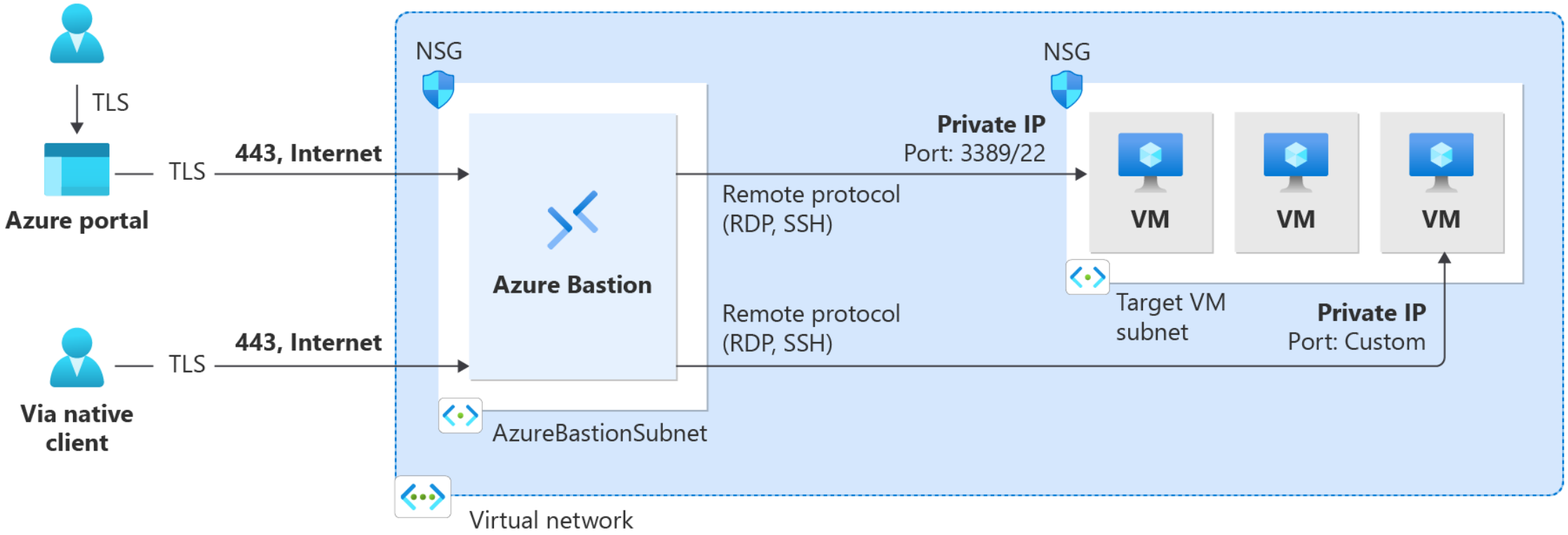
Private Endpoint



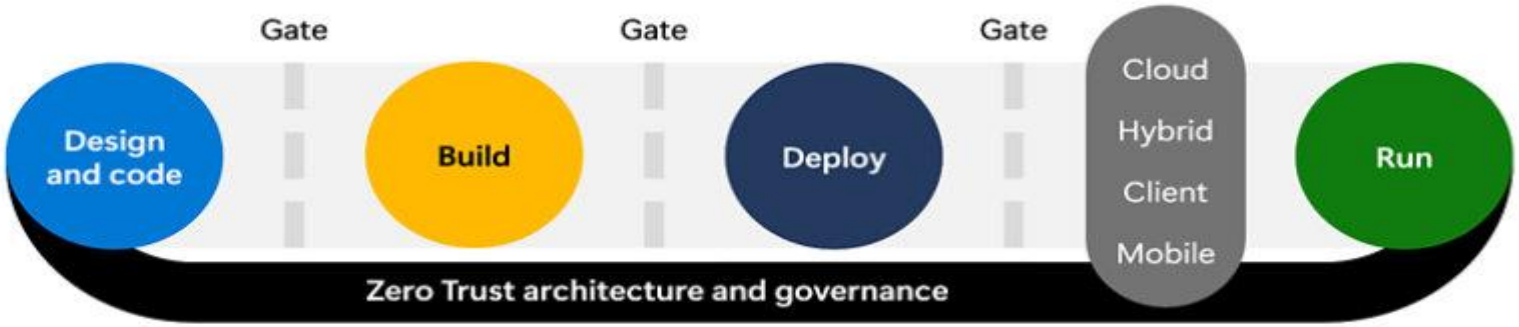
VPN


Azure region
Spoke
Spoke
HUB
VPN GW
Microsoft backbone
Internet edge
Internet edge
Internet edge
Internet
VPN-connected site
VPN-connected site
Point-to-site users

Azure Bastion



Security Development Lifecycle



Encryption

At rest

- AES 256 support across IaaS, PaaS and SaaS
- Client-side encryption: Azure has no visibility to your data
- Server-side encryption
  - Service managed keys offer control and convenience
  - Customer managed keys allow you to bring your own or generate new ones

In transit

- Traffic between datacenters encrypted point to point with Data-link layer encryption
- Data in transit to, from and between Windows VMs can be encrypted using TLS

Key Management

Azure supports Platform Managed (PMK) and Customer Managed (CMK) encryption Keys

Store and manage keys in the cloud:

- Azure Key Vault
- Azure Managed HSM
- Azure Dedicated HSM

Operationalize Secure Score

OPERATIONALIZE AZURE SECURE SCORE

- **What** – Assign stakeholders to use Secure Score in Azure Security Center to monitor risk profile and continuously improve security posture
- **Why** – Rapidly identifying and remediating common security hygiene risks can significantly reduce overall risk
- **How** – Set up a regular cadence (typically monthly) to review Azure secure score and plan initiatives with specific improvement goals. Gamify the activity if possible to increase engagement.

https://docs.microsoft.com/en-us/azure/security-center/security-center-secure-score

Important: The score you see depends on which subscriptions you have permission to

SUGGESTED PROCESS OWNERS

Monitor Secure Score	• **Vulnerability Management (or Governance/Risk/Compliance team)** • **Architecture Team** • **Responsible Technical Team (listed below)**

Improve Score Area	Responsible Technical Team
Compute and Apps Resources	App Services ▪ Application Development/Security Team(s) Containers ▪ Application Development and/or Infrastructure/IT Operations VMs/Scale sets/compute ▪ IT/Infrastructure Operations NOTE: Each DevOps team may be responsible for their application resources
Data & Storage Resources	SQL/Redis/Data Lake Analytics/Data Lake Store ▪ Database Team Storage Accounts ▪ Storage/Infrastructure Team
Identity and Access Resources	Subscriptions ▪ Identity Team(s) Key Vault ▪ Information/Data Security Team
Networking Resources	▪ Networking Team ▪ Network Security Team
IoT Security	▪ IoT Operations Team

Administration – Account protection

CRITICAL BEST PRACTICES

PASSWORDLESS OR MULTI-FACTOR AUTHENTICATION FOR ADMINS

- **What** – Require all critical impact admins to be passwordless (preferred) or require MFA.
- **Why –** Passwords cannot protect accounts against common attacks. https://channel9.msdn.com/events/Ignite/Microsoft-Ignite-Orlando-2017/BRK3016
- **How** –
  - **Passwordless (Windows Hello)** http://aka.ms/HelloForBusiness
  - **Passwordless (Authenticator App)** https://docs.microsoft.com/en-us/azure/active-directory/authentication/howto-authentication-phone-sign-in
  - **Multifactor Authentication** https://docs.microsoft.com/en-us/azure/active-directory/authentication/howto-mfa-userstates
  - **3rd Party MFA Solution**

NO STANDING ACCESS

- **What** – No standing access for critical impact admins
- **Why –** Permanent privileges increase business risk by increasing attack surface of accounts (time)
- **How** –
  - **Just in Time -** Enable Azure AD PIM or 3rd party solution) for all of these accounts
  - **Break glass –** Process for accounts (preferred for low use accounts like global admin)

Note: Text Message based MFA is now relatively inexpensive for attackers to bypass, so focus on passwordless & stronger MFA

Key Related Item is to increase administrator workstation security – http://aka.ms/secureworkstation

GRC – Segmentation

CRITICAL CHOICE

SEGMENTATION STRATEGY

- **What** – Identify security segments that are needed for your organization to contain risk
- **Why** – A clear and simple segmentation strategy enables stakeholders (IT, Security, Business Units) can understand and support it. This clarity reduces the risk of human errors and automation failures that can lead to security vulnerabilities, operational downtime, or both
- **How** – Select the segmentation approaches from the reference design and assign permissions and network controls as appropriate.

TIP

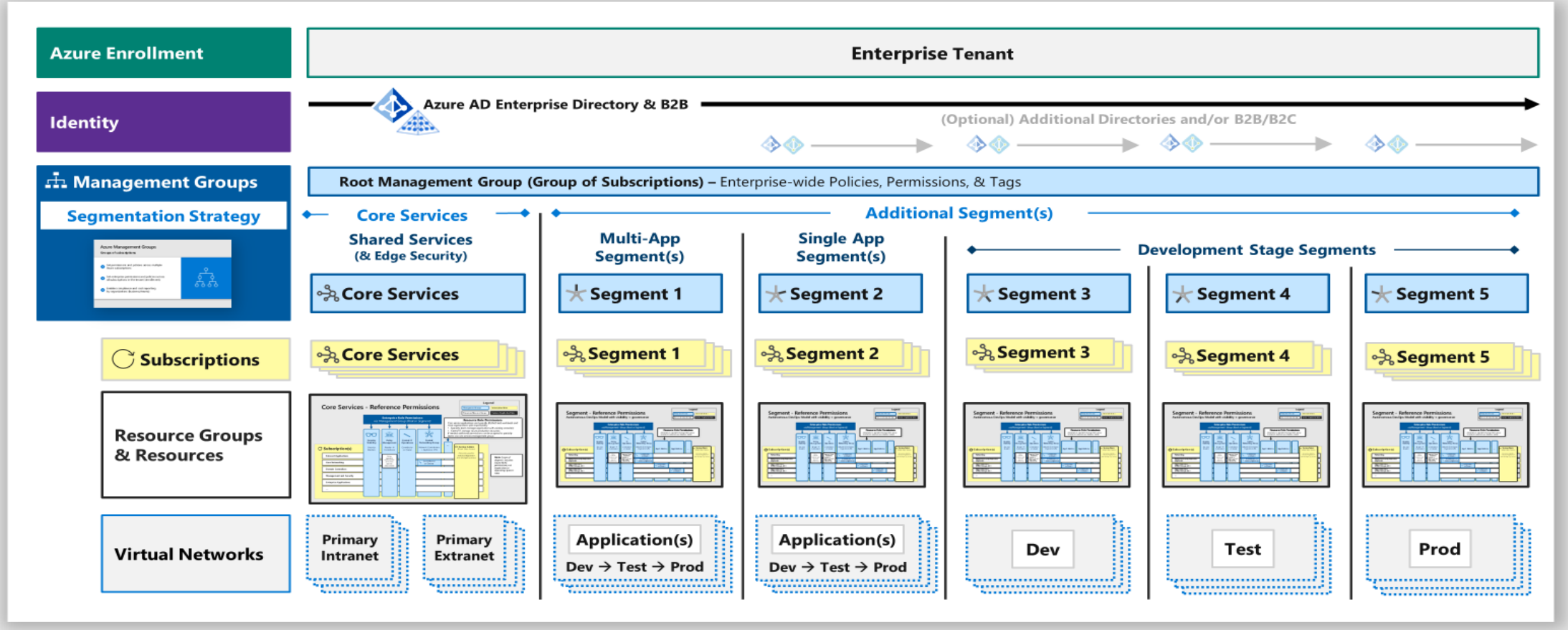
Minimize Complexity - Always consider whether a segment is needed or whether security monitoring provides enough risk mitigation
(each segments adds friction and overhead)



A GOOD SEGMENTATION STRATEGY:

1. **Enables Operations** – Minimizes operation friction by aligning to business practices and applications
2. **Contains Risk** - Adds cost and friction to attackers by
   - Isolating sensitive workloads from compromise of other assets
   - Isolating high exposure systems from being used as a pivot to other systems
3. **Is Monitored** – Security Operations should monitor for potential violations of the integrity of the segments (account usage, unexpected traffic, etc.)

Reference Design - Azure Administration Model



TD SYNNEX | Microsoft

Microsoft InnovAIte

Security Operations – Azure Alerts

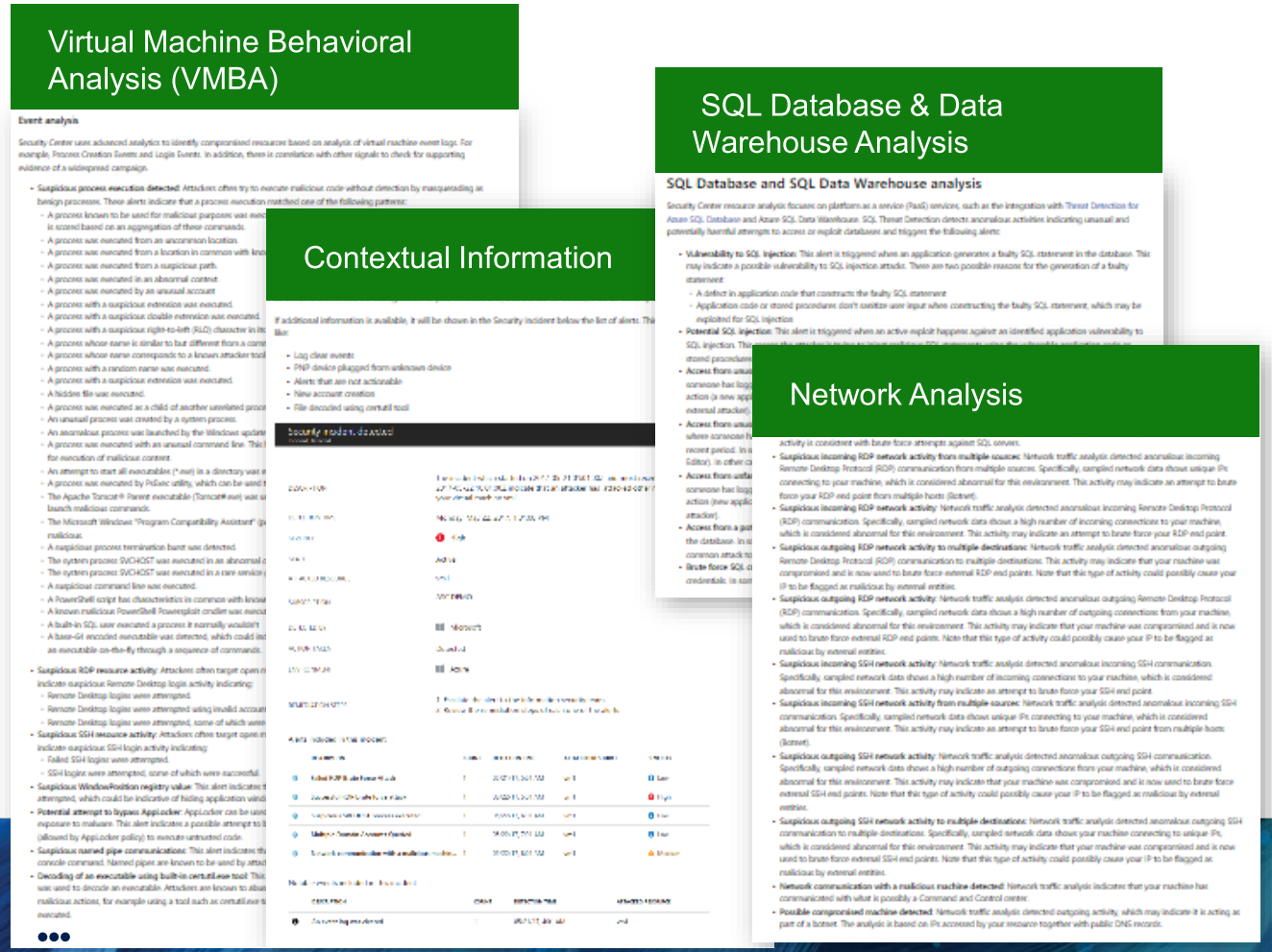
CRITICAL GUIDANCE

ASC BUILT IN SECURITY ALERTS

- **What** – Enable Azure Security Center security Alerts
- **Why** – Azure Security Center provides actionable detections for common attack methods (Alert List depicted on this slide), which can save your team significant effort on query development.

  These alerts are focused on high true positive rate by leveraging Microsoft's extensive threat intelligence, advanced machine learning, industry leading Endpoint Detection & Response (EDR) (MITRE report), and other approaches.
- **How** – Enable Azure Security Center (Recommend Standard Tier) https://docs.microsoft.com/en-us/azure/security-center/security-center-get-started

AZURE SECURITY CENTER ALERTS



Centralized Visibility

Azure Security Center

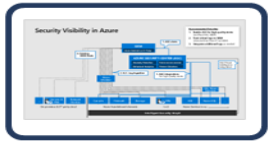
Azure Sentinel

IDENTIFY | PROTECT | DETECT | RESPOND | RECOVER

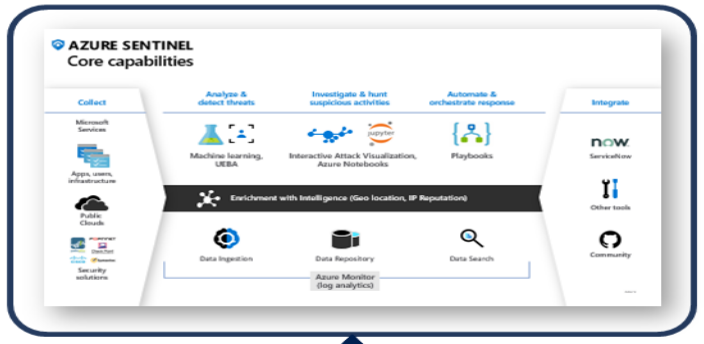
GRC Professional
Assess Risk & Compliance

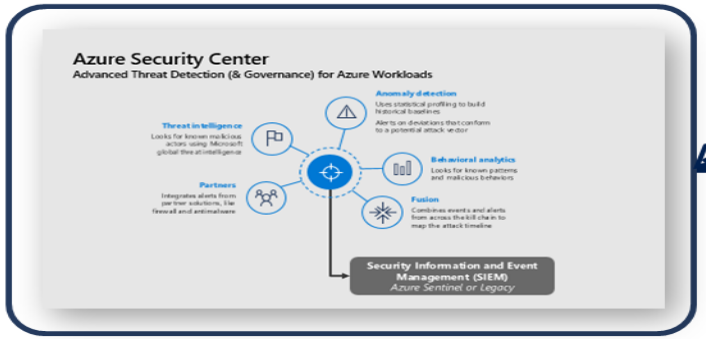
IT / Security Professional
Implement Protections

SOC Analyst
Primary Console
Alerts, Investigation



Log Flow

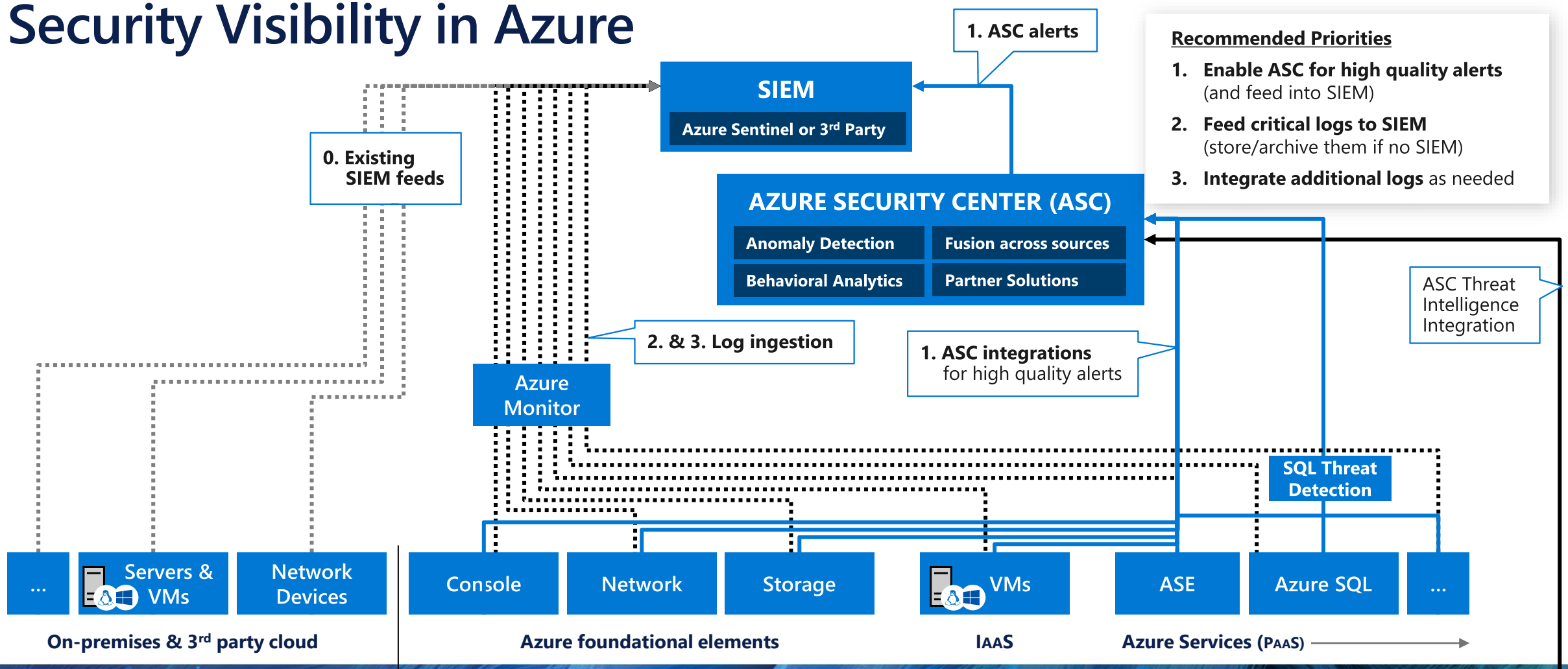




Generate Alerts

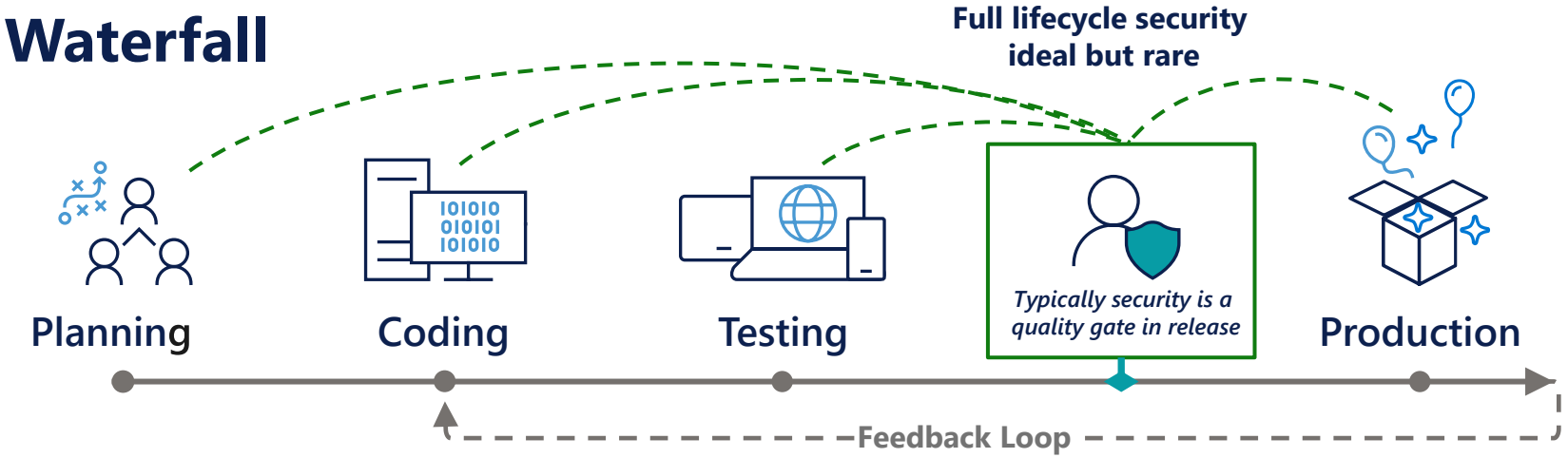
Identity | Endpoint | Cloud | Network | and more

Security Visibility in Azure



Role of Security in Development

Waterfall



Bias to Plan & Quality *(Weeks/Months)*

DevOps

Quality and Security risk mitigated by rapidly release of fixes



Bias to Speed & Agility *(Hours/Days)*

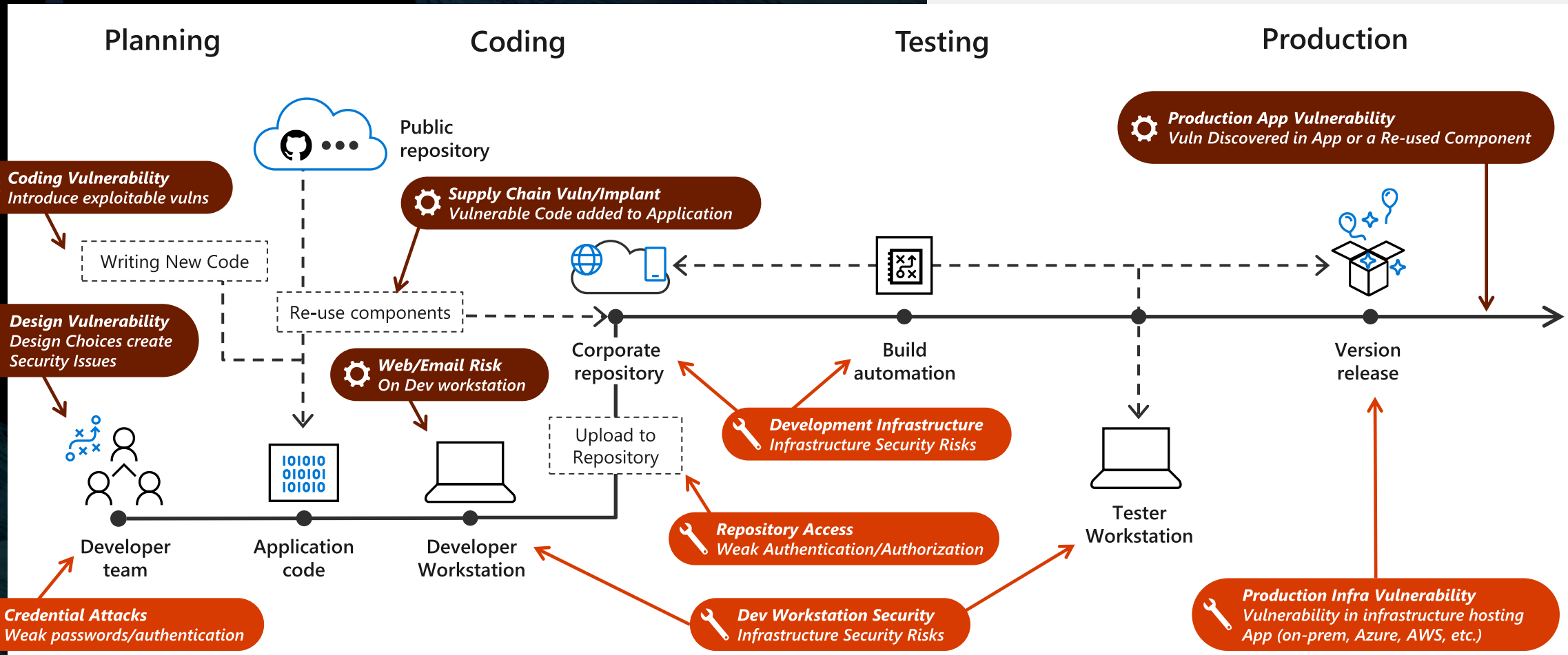
TD SYNNEX | Microsoft

Attacker Opportunities

Microsoft InnovAIte

Attacker Pivot Risks
Secondary attacks using compromised artifacts/access
- ***Lateral Movement*** *– Pass the hash/ticket/password/etc.*
- ***Development Artifacts*** *– Stolen keys/credentials, implanted malware or backdoors, etc.*

Legend
Developer-based attacks
IT and Operations-based attacks



TD SYNNEX | Microsoft

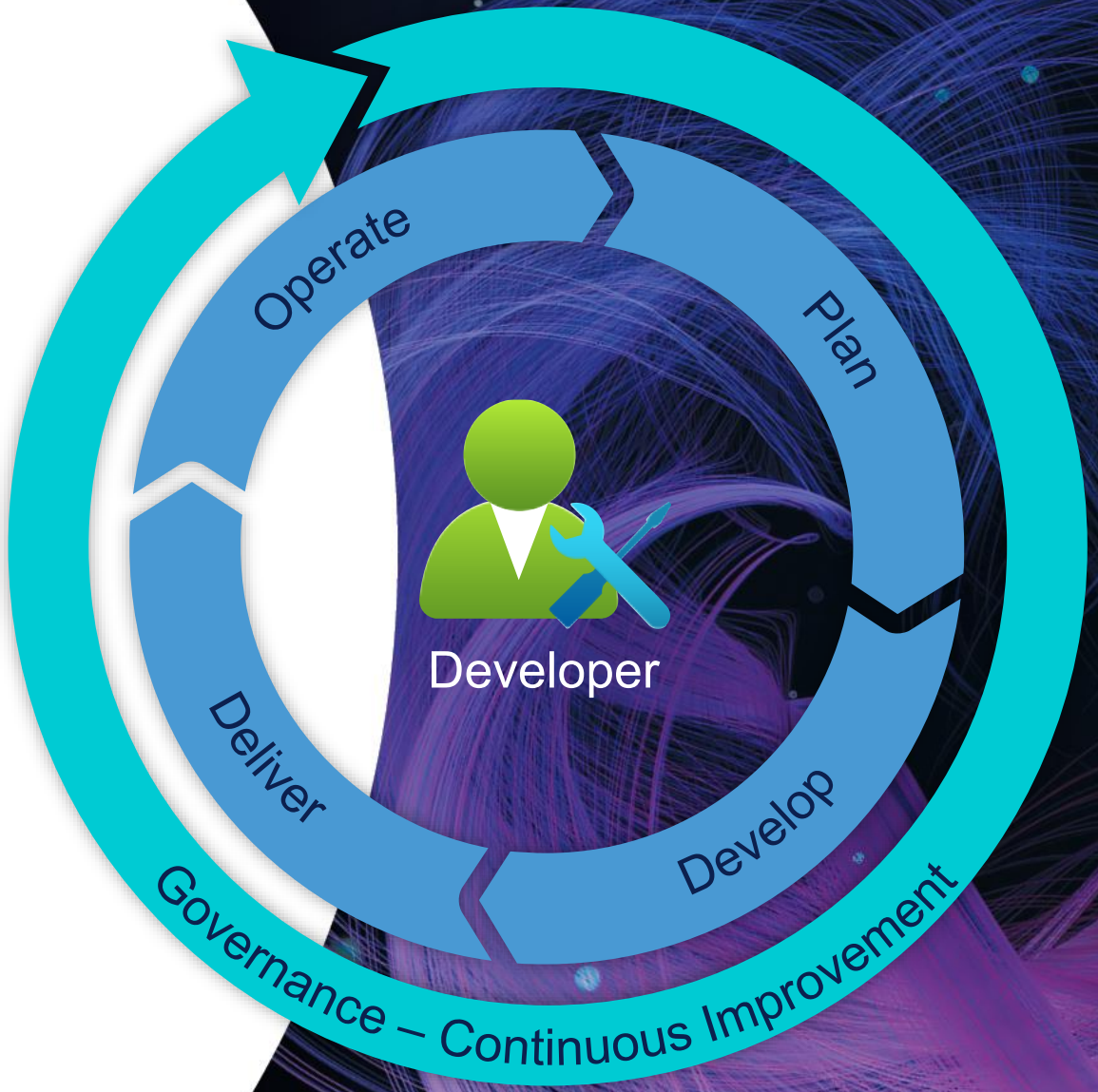
Microsoft InnovAIte

Securing DevOps:
Integrate security into the process

Every Sprint
Reduce risk natively in Continuous Integration / Continuous Delivery (CI/CD) with real-time developer guidance, build checks, and more

Periodic Actions
Regular risk reduction and governance activities like Threat modelling, Training, etc.

Vigilance and Response
Monitoring and Response processes to ensure close collaboration of Security and DevOps teams



Learnings from migrating Microsoft's IT environment to ~95% cloud-based infrastructure

TD SYNNEX | Microsoft

GRC – Key Responsible Parties

CRITICAL BEST PRACTICES

Microsoft InnovAIte

CLEAR LINES OF RESPONSIBILITY

- **What** – Designate the parties responsible for specific functions in Azure
- **Why** – Consistency helps avoid confusion that can lead to human and automation errors that create security risk.
- **How** – Designate groups (or individual roles) that will be responsible for key centralized functions

Most organizations map these closely to current on premises models.

TIP

Document and Socialize this widely with all teams working on Azure

Network Security	*Typically existing network security team* Configuration and maintenance of Azure Firewall, Network Virtual Appliances (and associated routing), WAFs, NSGs, ASGs, etc.
Network Management	*Typically existing network operations team* Enterprise-wide virtual network and subnet allocation
Server Endpoint Security	*Typically IT operations, security, or jointly* Monitor and remediate server security (patching, configuration, endpoint security, etc.)
Incident Monitoring and Response	*Typically security operations team* Investigate and remediate security incidents in SIEM or source console: • Azure Security Center • Azure AD Identity Protection
Policy Management	*Typically GRC team + Architecture* Set direction for use of Roles Based Access Control (RBAC), Azure Security Center, Administrator protection strategy, and Azure Policy to govern Azure resources
Identity Security and Standards	*Typically Security Team + Identity Team Jointly* Set direction for Azure AD directories, PIM/PAM usage, MFA, password/synchronization configuration, Application Identity Standards

Networks and Containment

CRITICAL BEST PRACTICES

INTERNET EDGE STRATEGY

- **What** - Choose whether to use Native Azure Controls or 3rd party Network Virtual Appliances (NVAs) for internetedge security (North-South).
- **Why** - Legacy workloads require network protection from internet sources and there are advantages to using either 1st or 3rd party controls to provide this..
- **Note** - Some organizations choose a hybridconfiguration where some VNets use advanced 3rd party controls and others use native controls

AZURE NATIVE CONTROLS

- Basic capabilities with simpleintegration & management
- Azure Firewall + Web App Firewall(in Application Gateway) offer basic security that is good enough for some scenarios with a fully stateful firewall as a service,built-in high availability, unrestricted cloud scalability, FQDN filtering, support for OWASP core rule sets, and simple setup and configuration

3RD PARTY CAPABILITIES

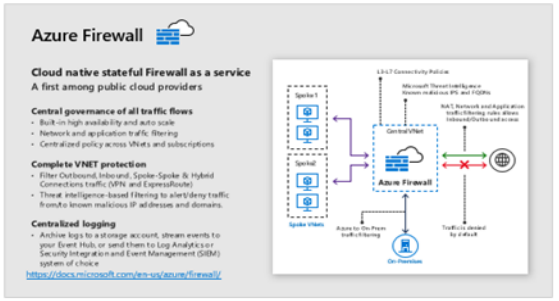
- Advanced security capabilities from existing vendors
- Next Generation Firewall (NGFW) and other 3rd party offerings
- Network virtual appliances in the Azure Marketplace include familiar security tools that provide enhanced network security capabilities
- Configuration is more complex, but allows you to leverage existing capabilities, and skillets

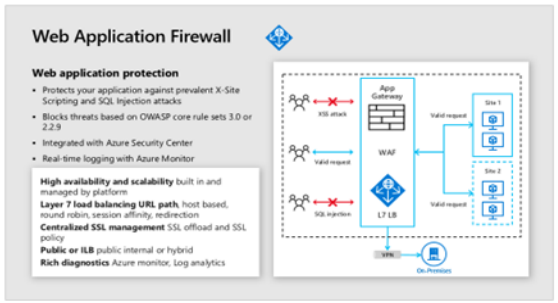
TD SYNNEX | Microsoft

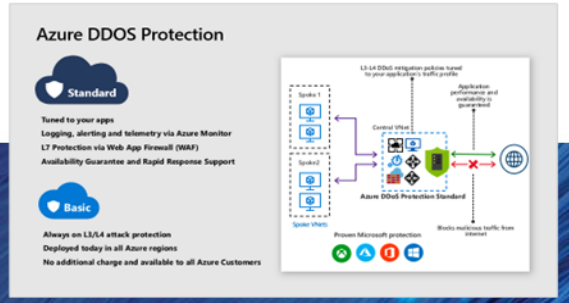
Microsoft InnovAIte

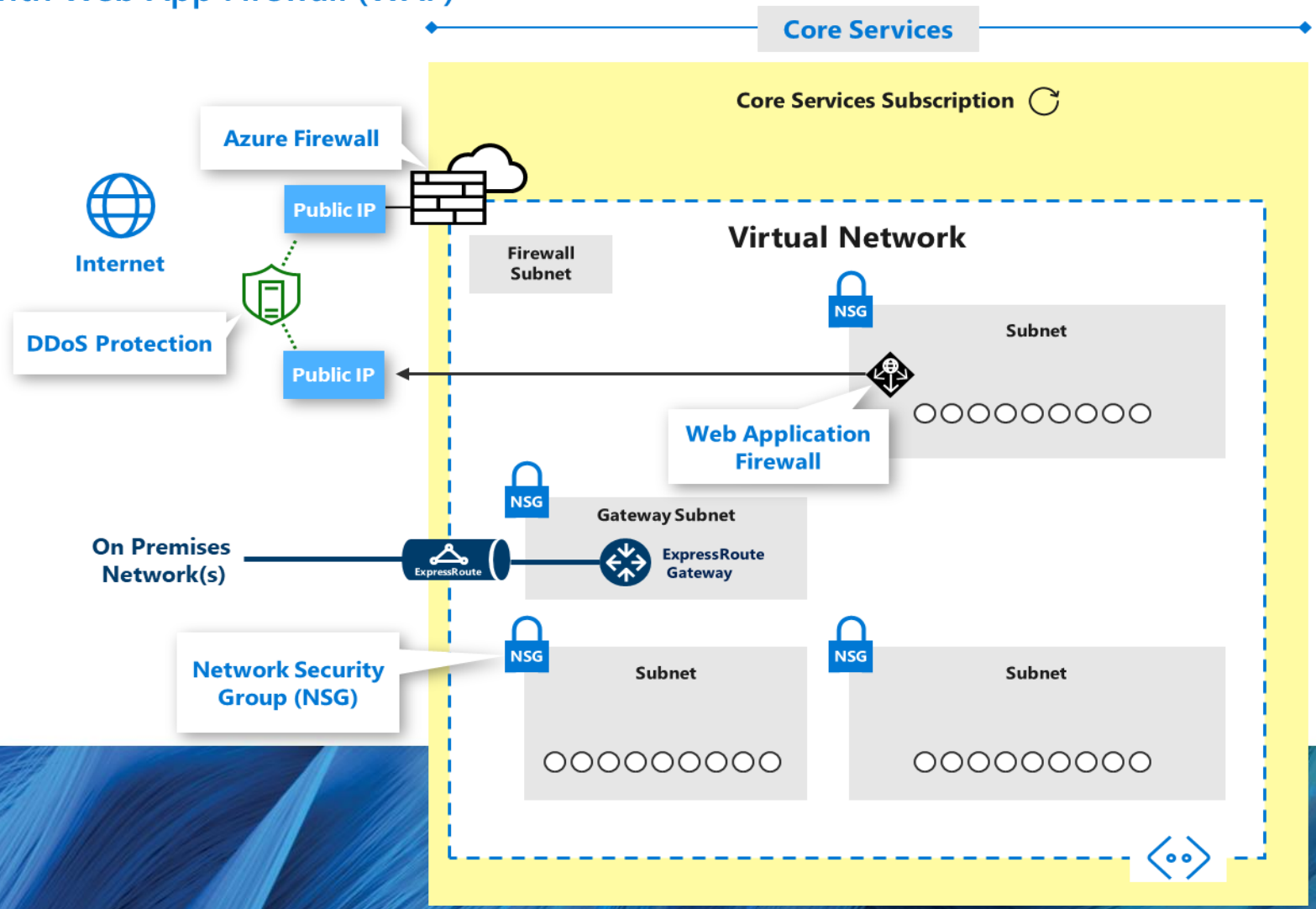
Reference Configuration with Native Controls

Azure Firewall + Application Gateway with Web App Firewall (WAF)



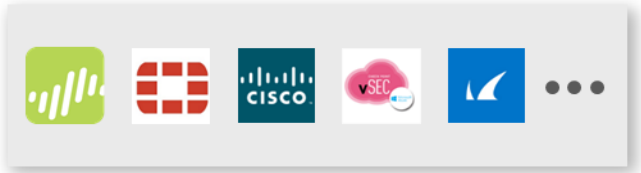






Reference Configuration with Virtual Appliance(s)

Next Generation Firewall with Integrated WAF/Proxy



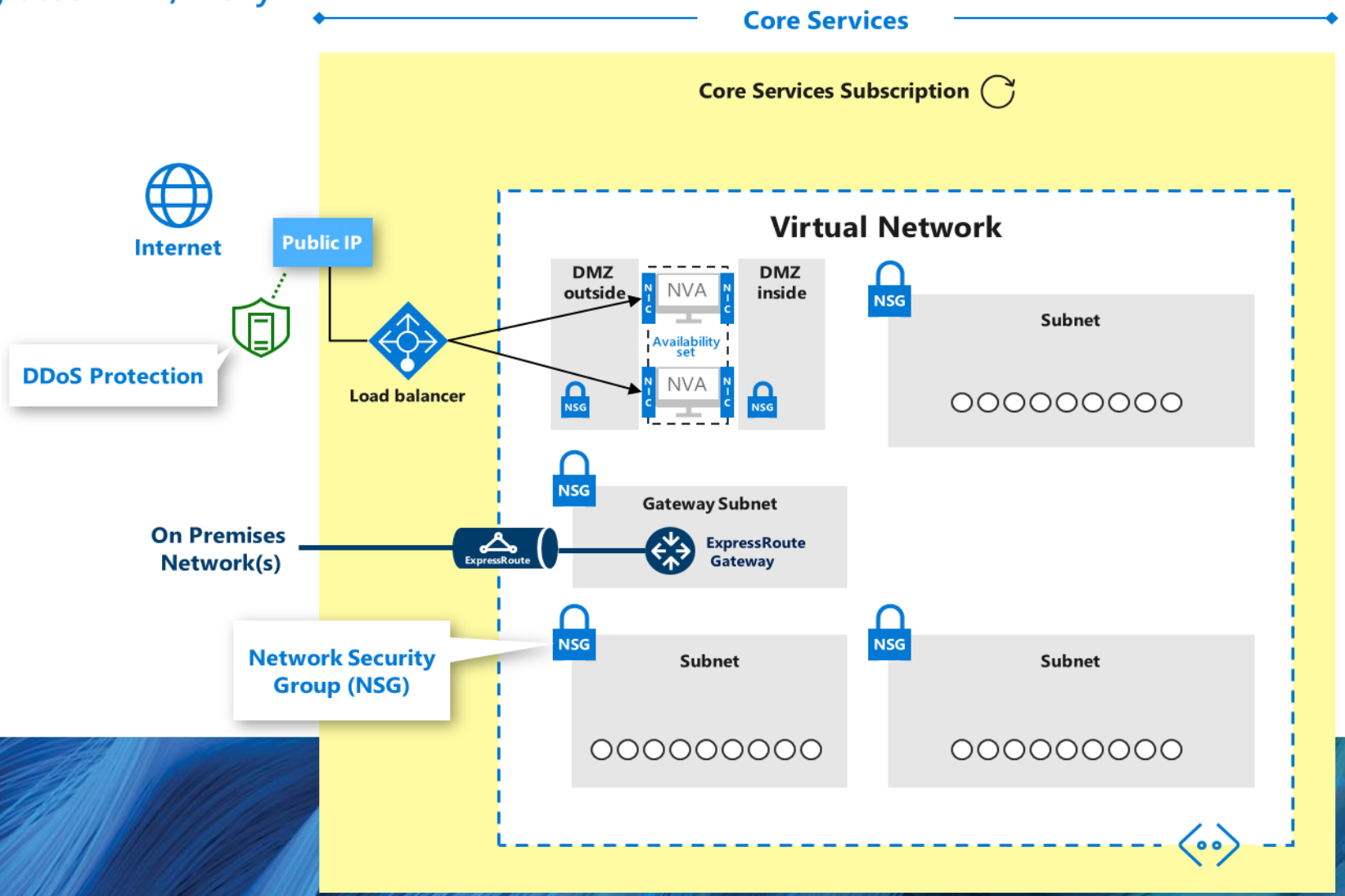
Popular Next Generation Firewalls available in Azure Marketplace

Load balancer enables scalability and availability

DDoS Protection Standard can be applied to public IP addresses.

More Information online

https://docs.microsoft.com/en-us/azure/architecture/reference-architectures/hybrid-networking/shared-services



Applications – WAF

CRITICAL BEST PRACTICES

USE WEB APP FIREWALL ON ALL INTERNET FACING APPLICATIONS

- **What -** Configure web application firewalls (WAFs) to protect all internet facing applications.
- **Why -** Common security vulnerability types are often exploited by attackers targeting applications (either as an ingress point to the environment or as the ultimate objective). WAFs are a critical mitigation for these attacks if you don't have a mature security development lifecycle (SDL) to find/fix these vulnerabilities. WAFs also serve as an important safety measure even if you do have a mature SDL (much like a parachute in aplane)..
- **How -** Microsoft includes WAF capabilities in Azure ApplicationGateway and many vendors offer these capabilities as standalonesecurity appliances or as part of next generation firewalls.

Web Application Firewall

- Protects your application against prevalent X-SiteScripting and SQL Injection attacks. Blocks threats based on OWASP core rule sets 3.0 or2.2.9
- Integrated with Azure Security Center.
- Real-time logging with Azure Monitor
- High availability and scalability built in and managed by platform
- Layer 7 load balancing URL path, host based,round robin, session affinity, redirection
- Centralized SSL management SSL offload and SSL policy
- Rich diagnostics Azure monitor, Log analytics

Networks and Containment - DDoS Mitigations

GENERAL GUIDANCE

DDOS MITIGATIONS

- **What -** Enable DDoS Mitigations for all business-critical webapplications, and services
- **Why -** DDoS attacks are prevalent and are very inexpensive toaccess on the dark markets
- **How -** Evaluate and select the best option for protecting yourcritical applications and services.
  - Azure DDoS standard.
  - 3rd party service

Azure DDOS Protection

- Standard –
  - Tuned to your apps
  - Logging, alerting and telemetry via Azure Monitor
  - L7 Protection via Web App Firewall (WAF)
  - Availability Guarantee and Rapid Response Support
- Basic –
  - Always on L3/L4 attack protection
  - Deployed today in all Azure regions
  - No additional charge and available to all Azure Customers

Network - Deprecating Legacy Technology

CRITICAL CHOICES

CLASSIC NETWORK INTRUSION DETECTION/PREVENTION SYSTEMS (NIDS/NIPS)

- **What -** Choose whether to add existing NIDS/NIPS capabilities on Azure
- **Why -** The Azure platform already filters malformed packets and most classic NIDS/NIPS solutions are typically based on outdated signature-based approaches which are easily evaded by attackers and typically produce high rate of false positives.
- **How -**
  - Do Not Add (Default Recommendation)
  - Add to Azure tenant

NETWORK DATA LOSS PREVENTION (DLP)

- **What -** Choose whether to add Network DLP capabilities on Azure
- **Why -** Network DLP is increasingly ineffective at identifying both inadvertent and deliberate data loss. This is because most modern protocols and most attackers use encryption (most available attacker toolkits have encryption built in)
- **How -**
  - Do Not Add (Default Recommendation)
  - Add to Azure tenant

TD SYNNEX | Microsoft

Microsoft InnovAIte

Q&A

- Weekly Webinars
- Free Training
- No-Cost Accelerators
- Azure Migration
- Pre-Sales Support
- Resource Guide

Scan for Resources

Your Path to 4X Growth - TDSYNNEX Cloud Engineering

TD SYNNEX | Microsoft

Microsoft InnovAIte

Thank you

Anil.Patel@TDSynnex.com

CloudEnablementServices@TDSynnex.com

